



Database Management System (303105203)

Unit – 8: Database Security

Dr. Dhanraj Verma,
Professor, CSE-AIML





Unit Required

- Security
- Integrity
- Authentication
- Authorization
- Data encryption
- Access control
- Intrusion detection system
- Sql injection



Security and Integrity

Security	Integrity
Security ensures that things users are doing are only what they are allowed to do.	Integrity ensures that the things the users are trying to do are correct.
It deals with protection of data.	It deals with the data.
Data security defines a prevention of data corruption through the use of controlled access mechanism.	Data integrity defines a quality of data, which guarantees the data is complete and has a whole structure.
It refers to making sure that data is accessed by its intended user.	It refers to structure of data and how it matches the schema of database.
Authentication, authorization, encryptions are means of security.	Backing up, error detection, error correction are means of data integrity.

Database Security

- Database security refers to the collective measures used to protect and secure a database or database management software from illegitimate use and malicious threats and attacks. Protection of data from unauthorized user is data security.
- Database security is generally planned, implemented and maintained by a database administrator and or other information security professional.
- It is most important to secure the database from unauthorized user. For example, if your company collects any data about customers, suppliers, or the wider community, it is stored on a database somewhere.
- This data may be sensitive and private, and can be subject to strict privacy agreements including those referred to above. Your customers may provide you with an email address, postal address, and phone number when they purchase something from you. It is very important to secure their information.

Database Security

- It includes a multitude of processes, tools and methodologies that ensure security within a database environment.
- Data Security is a process of protecting files, databases, and accounts on a network by adopting a set of controls, applications, and techniques that identify the relative importance of different datasets, their sensitivity, regulatory compliance requirements and then applying appropriate protections to secure those resources.

Objectives Database Security

- 1) **Secrecy:** Information should not be disclosed to unauthorized users. E.g. student's grade cannot to examine by student.
- 2) **Reliability:** Only authorized users modify the data. E.g. student see their result but not modified them.
- 3) **Availability:** Authorized uses should not be denied access. E.g. an instructor should be allowed to change result.

Authorization and Authentication

Authentication	Authorization
Determines whether users are who they claim to be	Determines what users can and cannot access
Checks the detail of an entity with a view of identifying the entity.	Check the privileges of a user before providing the access.
In general, authentication needs a username and password.	The factors essential for authorization are likely to differ by the security level.
Authentication verifies user's credentials.	Authorization validates user's permissions.
Authentication determines whether the person is user or not.	While it determines What permission do user have?

Audit trail

Individual Accountability - Audit trails are a technical mechanism that help managers maintain individual accountability. By advising users that they are personally accountable for their actions, which are tracked by an audit trail that logs user activities, managers can help promote proper user behavior. Users are less likely to attempt to circumvent security policy if they know that their actions will be recorded in an audit log.

Intrusion detection - Intrusion detection refers to the process of identifying attempts to penetrate a system and gain unauthorized access. If audit trails have been designed and implemented to record appropriate information, they can assist in intrusion detection.

Detailed Insight - Because an audit log tracks how long and how frequently individual users access a document, it can be used to gain insight into which investors or potential partners are most interested in a business, enabling the company to be more strategic with its negotiations.

Data Encryption

1) *Symmetric key encryption:*

- In symmetric encryption the encryption key is also used as the decryption key data encryption standard is the example of symmetric encryption.
- By using a symmetric key, fast encryption and decryption is possible for routine use with sensitive data in the database. A message encrypted with a secret key can be decrypted only with the same secret key. Algorithms used for symmetric key encryption are called **secret key algorithms**.
- The major liability associated with secret-key algorithms is the need for sharing the secret key.
- A possible method is to derive the secret key from a user-supplied password string by applying the same function to the string at both the sender and receiver; this is known as a *password-based encryption algorithm*.

Data Encryption

- The strength of the symmetric key encryption depends on the size of the key used.
- Drawback of symmetric encryption is all authorized users must be told the key, so it is easily known to intruder.

2) *Public key encryption.*

- Public key encryption algorithm uses pair of keys, one of which is a secret key and one is public key.
- These two keys are mathematically linked with each other.
- The use of two keys can have profound consequences in the areas of confidentiality, key distribution, and authentication. The two keys used for public key encryption are referred to as the **public key** and the **private key**.

Data Encryption

- A public key encryption scheme, or *infrastructure*, has following ingredients:
- **Plaintext.** This is the data or readable message that is fed into the algorithm as input.
- **Encryption algorithm.** This algorithm performs various transformations on the plaintext.
- **Public and private keys.** These are a pair of keys that have been selected so that if one is used for encryption, the other is used for decryption. The exact transformations performed by the encryption algorithm depend on the public or private key that is provided as input.
- For example, if
- a message is encrypted using the public key, it can only be decrypted using the private key.
- **Cipher text.** This is the scrambled message produced as output. It depends on the plaintext and the key. For a given message, two different keys will produce two different ciphertexts.
- **Decryption algorithm.** This algorithm accepts the ciphertext and the matching key and produces the original plaintext.

Access control

- Access control is a security technique that regulates who or what can view or use resources in a computing environment.
- Access control is basically identifying a person doing a specific job, authenticating them by looking at their identification, then giving that person only the key to the door or computer that they need access to and nothing more.

1) Discretionary access control.

- The typical method of enforcing discretionary access control in a database system is based on the granting and revoking of privileges.
- In DAC, the owner of the object specifies which subjects (user) can access the object.
- Here user is given access privileges to access data base objects or data items.

Access control

- In this method a single user can have different rights on different data items, as well as different user can have different rights on the same data item.
- SQL support discretionary access control through the GRANT and REVOKE commands.
- GRANT:
 - This command gives rights to user for a data items.
Syntax: GRANT privilege ON object TO user [WITH GRANT OPTION]
- REVOKE:
 - This commands takes back rights from user for a data items.
Syntax: REVOKE privilege ON object FROM user {RESTRICT/CASCADE}

Access control

- **2) Mandatory Access Control.**
- This is an all-or-nothing method: A user either has or does not have a certain privilege.
- A user can access object of particular security level only if he has proper clearance level.
- The DBMS determines whether a given user can read or write a given object based on some rules.
- This rule makes sure that sensitive data can never be passed to a user without necessary clearance.
- The commonly used mandatory access control technique for multi-level security uses 4 components as given below:
 - Subjects: Such as users, accounts, programs etc.
 - Objects: Such as relations, tuples, attributes, views etc.
 - Clearance level & Security Level: Such as top secret(TS), secret(S), Confidential(C), Unclassified(U). Each object is classified into one of these 4 classes.



Access control

3) Role based Access control.

- Basic notion of role-based Access control is that privileges and other permissions are associated with organizational **roles** rather than with individual users. Individual users are then assigned to appropriate roles. Roles can be created using the CREATE ROLE and DESTROY ROLE commands.
- The GRANT and REVOKE commands can then be used to assign and revoke privileges from roles, as well as for individual users when needed.
- For example, a company may have roles such as sales account manager, purchasing agent, mailroom clerk, customer service manager, and so on.

Intrusion Detection System (IDS)

- An **Intrusion Detection System (IDS)** is a system that monitors **network traffic** for suspicious activity and issues alerts when such activity is discovered. It is a software application that scans a network or a system for harmful activity or policy breaching.
- The purpose of intrusion detection system in database system is to detect transactions that access data without permission.
- Intrusion prevention systems also monitor network packets inbound the system to check the malicious activities involved in it and at once sends the warning notifications.

Intrusion Detection System (IDS)

➤ **Classification of Intrusion Detection System:**

IDS are classified basically into 2 types:

➤ **1) Network Intrusion Detection System (NIDS):**

Network intrusion detection systems (NIDS) are set up at a planned point within the network to examine traffic from all devices on the network.

➤ It performs an observation of passing traffic on the entire subnet and matches the traffic that is passed on the subnets to the collection of known attacks.

Intrusion Detection System (IDS)

2) Host Intrusion Detection System (HIDS):

Host intrusion detection systems (HIDS) run on independent hosts or devices on the network. A HIDS monitors the incoming and outgoing packets from the device only and will alert the administrator if suspicious or malicious activity is detected.

- It takes a snapshot of existing system files and compares it with the previous snapshot.
- If the analytical system files were edited or deleted, an alert is sent to the administrator to investigate.

SQL Injection

- SQL injection is one of the most common threats to a database system.
- SQL injection is a code injection technique that might destroy your database.
- Web programs and applications that access a database can send commands and data to the database, as well as display data retrieved from the database through the Web browser.
- SQL injection is one of the most common web hacking techniques.
- SQL injection is the placement of malicious code in SQL statements, via web page input.
- In an **SQL injection attack**, the attacker injects a string input through the application, which changes or manipulates the SQL statement to the attacker's advantage.

SQL Injection

- An SQL injection attack can harm the database in various ways, such as unauthorized manipulation of the database or retrieval of sensitive data.
- It can also be used to execute system-level commands that may cause the system to deny service to the application.
- **SQL Manipulation.** A manipulation attack, which is the most common type of injection attack, changes an SQL command in the application—for example, by adding conditions to the WHERE-clause of a query, or by expanding a query with additional query components using set operations such as UNION, INTERSECT, or MINUS.
- **Code Injection.** This type of attack attempts to add additional SQL statements or commands to the existing SQL statement by exploiting a computer bug, which is caused by processing invalid data. The attacker can inject or introduce code into a computer program to change the course of execution.

SQL Injection

- **Function Call Injection.** In this kind of attack, a database function or operating system function call is inserted into a vulnerable SQL statement to manipulate the data or make a privileged system call. For example, it is possible to exploit a function that performs some aspect related to network communication.

× ○ DIGITAL LEARNING CONTENT



Parul[®] University



www.paruluniversity.ac.in